



Project JANUS

A closed-loop adversarial AI system for payment fraud:
identify, generate at fidelity, and defend.

Submitted to the Mastercard Innovation Challenge 2026, AI Defense Lab for Payment Security, Global Fintech Fest, Mumbai.

Every figure in this document is read at build time from the JSON artifacts the pipeline writes to `data/processed/`. Nothing here is transcribed by hand, so no number in this document can outlive the run that produced it. Where an artifact is absent, the section says so rather than carrying forward an older figure.

What is in the repository

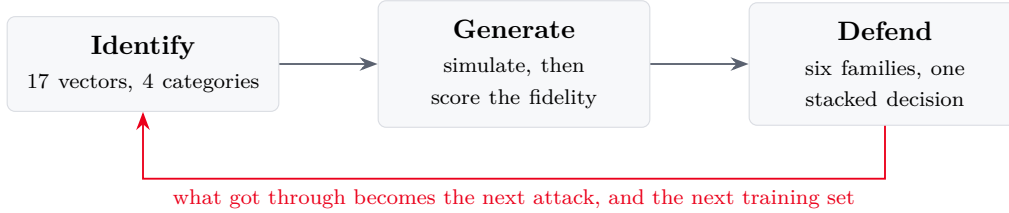
- `janus/`: the three pillars as one Python package: `identify/`, `generate/`, `defend/`, `orchestrate/`.
- `backend/`, a FastAPI service over the measured artifacts and the live sandbox.
- `frontend/`, the web prototype.
- `tests/`: offline test suite; no network, no credentials.

Contents

1	The loop	3
1.1	An honesty convention, stated once	3
2	Identify: the attack atlas	3
2.1	The vectors that are simulated end to end	4
2.2	The vectors mapped but not simulated end to end	4
2.3	Why the identity category exists at all	5
3	Generate: simulation, and how close it actually is	5
3.1	Fidelity scorecards	6
3.2	The synthetic-identity generator, and a result we had to throw away	6
4	Defend: six families, one decision	7
4.1	Does the graph actually add anything?	7
4.2	The stack	7
4.3	Where the decisions actually go	8
4.4	Why a decline happened	8
4.5	A feature removed on purpose	9
4.6	Can it run inline?	9
5	The closed loop	9
5.1	Agentic arm: a frontier model attacking an agent	9
5.2	Tabular arm: black-box evasion and hardening	9
6	Real-world feasibility in live payments	10
6.1	Where each control sits in an authorization	10
6.2	Fitting existing rails	10
6.3	What would have to happen next	11
7	Limitations	11
8	Reproducing this	11

1 The loop

The brief asks for three pillars. The reason to build them as one system rather than three is that each one's output is the next one's input, and the third one's failures are the first one's next target. That cycle is the product:



Two things follow from taking the loop literally rather than as a diagram.

The defense trains on its own failures. In the agentic arm, every payload that reaches a completed checkout is folded into the Mandate Firewall's text classifier before the next round runs. In the tabular arm, every adversarial example that evaded the scorer is appended to the training set, still labelled fraud, and the model is refit. Neither arm assumes this works: both measure whether the attacker's win rate actually falls, and report a plateau as a plateau.

Fidelity is a measurement, not an adjective. A generator that produces obviously synthetic data trains a defense against nothing. So every synthetic batch is scored by training a classifier to separate it from real data (an AUC of 0.5 means it cannot) and that number is reported even when it is unflattering.

1.1 An honesty convention, stated once

Across this document and the prototype, every attack vector carries one of three statuses, and the status is derived from what the code actually does rather than asserted separately:

- **simulated**; a generator produces instances *and* a detector is trained and evaluated against them, with measured numbers persisted.
- **modeled**: a specific structural mechanism with a partial hook in the sandbox or rules, but no dedicated end-to-end generator/detector pair.
- **taxonomy only**, researched and documented; nothing is built.

Nine of the seventeen entries are not fully simulated, and the coverage figures below say so.

2 Identify: the attack atlas

The atlas holds **17** distinct GenAI-enabled payment-fraud vectors across four categories: **8** simulated end to end, **2** modeled, **7** taxonomy only. Each entry records its mechanism, the rails and channels it targets, the precursor signals and observable features a risk system could actually key on, its grounding citation, and the module paths that simulate and detect it. The prototype's coverage claim is computed from that file, so it cannot overstate what exists.

Category	Simulated	Modeled	Taxonomy	Total
Identity & Onboarding Fraud	1	0	3	4
Social-Engineering & Authorization Fraud	1	1	3	5
Transaction & Network-Level Attacks	3	0	1	4
Agentic Commerce Fraud	3	1	0	4
All	8	2	7	17

2.1 The vectors that are simulated end to end

ID	Attack	Mechanism
A1	Synthetic Identity Fraud 2.0	LLM-generated fake identities with internally consistent synthetic credit histories; diffusion-generated selfies matched to fabricated ID documents, defeating document+selfie...
B6	Deepfake "Emergency" Voice/Video Scams	Cloned voice/video of a family member or executive used to authorize an urgent push payment. Deliberately does not generate or detect audio; the downstream transaction fingerprint...
C10	LLM-Automated Card Testing ("Card-ing Bots")	Agents that iterate BIN ranges and mutate transaction parameters, adapting to declines to evade velocity checks, a rapid burst of small, varied-amount authorization attempts with a high...
C11	Adversarial Evasion of Scoring Models	Minimally-perturbed fraud transactions crafted via black-box query-based search to slip under a deployed model's decision threshold, without changing the underlying fraudulent intent.
C12	Synthetic Mule-Network Orchestration	AI-coordinated fan-in (many sources -> one mule account) followed by fan-out (one mule -> many sinks) within a tight time window, skimming a cut before forwarding; structuring designed...
D14	Prompt-Injection Hijack of Shopping Agents	Malicious content embedded in a merchant's own product listing covertly instructs a consumer's AI shopping agent to change its selection, quantity, stated price, or the account a payment...
D16	Adversarial Listing Manipulation	GenAI-crafted product listings and reviews engineered specifically to manipulate an autonomous purchasing agent's decision logic, biasing product selection via fake authority/safety...
D17	Agent Token Theft & Replay	A leaked or misdirected agent payment credential is used by a party other than the authenticated session, modeled here as the Vault Whisper mechanism: injected content persuades the...

2.2 The vectors mapped but not simulated end to end

These carry the same atlas record as the eight above, mechanism, rails, channels, actors, precursor signals, observable features and a grounding citation, and are the next targets for the loop. They are listed rather than counted so the breadth of the taxonomy can be judged and not taken on trust.

ID	Attack	Status	Mechanism
A2	Deepfake Video-KYC Bypass	taxonomy only	Real-time face-swap/diffusion models defeating liveness checks during remote video onboarding.
A3	AI-Forged Supporting Documents	taxonomy only	Diffusion/template models forging utility bills, payslips, and IDs realistic enough to pass OCR-based document verification.
A4	Voice-Clone Account Takeover	taxonomy only	Cloned voice used against IVR authentication or call-center OTP-reset flows to take over an existing account (distinct from A6’s downstream...
B5	Hyper-personalized AI Phishing/Smishing	taxonomy only	LLM-crafted messages personalized at scale using scraped/breached data, driving the victim to authorize a push payment.
B7	AI Romance / "Pig-Butchering" Bots	taxonomy only	Persistent LLM-run chat personas that groom victims over weeks toward fraudulent "investment" payments.
B8	GenAI Fake Storefronts & Support Chat	modeled	LLM+template-generated phishing storefronts and fake support chatbots that harvest card data. Structurally related to Category D’s catalog-...
B9	Voice-Cloned OTP/2FA Social Engineering	taxonomy only	Impersonating the cardholder in real time against bank call-center authentication to authorize a transaction or reset a credential.
C13	GenAI-Coached Friendly Fraud	taxonomy only	LLMs generating optimized, individually-plausible chargeback narratives at scale to maximize first-party dispute win-rate.
D15	Synthetic / Impersonated Agent Identity	modeled	A fraudulent agent impersonates a legitimate merchant or consumer agent inside an agent-to-agent negotiation to initiate an unauthorized...

2.3 Why the identity category exists at all

Category A was, until late in the build, the one category with four entries and nothing behind any of them. It is also the category where a naive benchmark is easiest to fake, which is covered in §3.2; the first version of that generator scored a perfect 1.000 and had to be rebuilt.

3 Generate: simulation, and how close it actually is

Four independent signals score every synthetic batch, because a generator can fail in four different ways and each metric only catches one of them: per-feature distributional distance (Wasserstein, Kolmogorov-Smirnov, Jensen-Shannon), a correlation-matrix delta that catches a generator nailing every marginal while destroying the joint structure, a *real-versus-synthetic distinguisher AUC*, and (for the graph generator) a topology comparison. The distinguisher is the strongest of the four, because unlike a fixed set of hand-chosen statistics it is free to find whatever actually separates the two distributions. **An AUC of 0.500 is perfect and 1.000 is a total failure**, which is the opposite of every other score in this document.

3.1 Fidelity scorecards

Batch	Distinguisher AUC	Distance from ideal	Corr. delta	Rows
tabular synthesis ulb legit	0.607	0.107	0.033	5000
tabular synthesis ulb fraud	0.556	0.056	0.166	492
graph mule ring amounts	0.818	0.318	n/a	599
sequence voice scam amounts	0.735	0.235	n/a	200

The mule-ring batch additionally carries a topology comparison against the real transfer network: degree-distribution KS **0.063**, clustering-coefficient delta **0.000**. This is the check that catches an injected ring which matches the amount distribution perfectly and still sits in the network as an obviously synthetic clique; a failure mode no per-feature comparison can see.

Reading these honestly

None of these batches is indistinguishable from real data. The tabular synthesizer is a Gaussian copula fitted per class; it reproduces marginals well and joint structure less well, and the correlation delta is where that shows. Reporting the number rather than tuning the metric is the point: a fidelity score that is always good is a fidelity score that is not measuring anything.

3.2 The synthetic-identity generator, and a result we had to throw away

The first version of this generator drew every fraudulent application from one distribution: throw-away email domains, heavy device and IP reuse, bot-speed form completion. The detector scored precision 1.000, recall 1.000, PR-AUC 1.000. That is not a good result; it is the signature of two populations separable on a single near-disjoint feature. Feature importance confirmed it, one column carried 62% of the model.

Real rings buy their way out of exactly those tells, and cheaply. Aged mailboxes on mainstream domains are a commodity purchase; residential proxy pools drop IP reuse to one; anti-detect browsers mint a fresh fingerprint per session; replaying recorded human keystroke timings defeats a dwell-time threshold. So sophistication became an explicit per-ring property, and the control group was given genuine thin-file applicants, first-time borrowers, recent arrivals, who share the fraud population’s headline signature and are precisely the people a lazy model debanks.

Ring type	What the ring pays for	Recall
Cheap	One device, one subnet, throwaway domains, bot-speed form fill	100.0%
Moderate	Partial rotation, mixed mailbox age, some human pacing	90.3%
Advanced	Fresh device and residential IP per application, aged mainstream mailboxes, replayed human timing	62.1%

Aggregate PR-AUC is **0.953**. The number that matters more is the cost to legitimate people: **0.62%** of genuine thin-file applicants are flagged, against 0.03% of established customers. Both are reported, because a detector that scores well on the aggregate while failing the first group is declining people for being new.

Limitation, stated plainly: both sides of this population are synthetic, because no public dataset labels synthetic-identity applications. What makes the result meaningful is not the score but the structure of the control group and the sophistication gradient; a detector that could not tell an advanced ring from a first-time borrower would show it here.

4 Defend: six families, one decision

Fraud does not arrive in one shape. It arrives as a row of features, as a sequence of attempts against one card, as a subgraph of accounts moving money between them, as a paragraph of text inside a product listing, and as an application form. One model architecture cannot cover that, so each family is trained on the substrate it is built for and measured there.

Every score below is PR-AUC, not accuracy or ROC-AUC. Fraud is well under 1% of traffic in every dataset here; a model that flags nothing scores 99% accuracy and a respectable ROC-AUC. Precision-recall area is the only one of the three that degrades honestly under that imbalance.

Family	Catches	PR-AUC	Recall	Prec.	Measured on
Gradient-boosted trees	Fraud in ordinary card traffic	0.877	84%	89%	284807 real transactions, 492 fraudulent
GNN + trees (hybrid)	Rings no single transaction reveals	0.592	50%	69%	606270 nodes, 3460248 edges
Onboarding scorer	Synthetic identities at account opening	0.953	89%	93%	48900 applications ⁴
Account graph features	Money-mule networks	1.000	100%	100%	60 injected rings ¹
Sequence transformer	Automated card-testing runs	1.000	100%	100%	690 simulated histories ²
Behavioural fingerprint	Voice-clone authorised push payment	0.493	42%	80%	45060 transactions ³

¹ Scored against rings injected into real mobile-money data, not confirmed real mule accounts; the topology is realistic, the labels are ours.

² A perfect score on entirely synthetic sequences. It shows the architecture works; it is not a real-world detection rate.

³ The hardest problem here, and the score says so. The payment is genuinely authorised by the real customer, so the only signal is that it does not look like their normal behaviour. This is why the signal routes to review rather than decline.

⁴ Fully synthetic population on both sides; see §3.2 for why the control group is what makes it meaningful.

4.1 Does the graph actually add anything?

A graph neural network is easy to add and hard to justify, so it was ablated rather than assumed. Alone, the GraphSAGE encoder reaches PR-AUC 0.412, worse than the tabular model. Concatenating its node embeddings into the gradient-boosted model reaches **0.592**. The relational signal and the tabular splitting are complementary, not redundant: the graph sees fraud propagating between transactions that share a card, device or email even when each row looks unremarkable, which is structurally invisible to a row-independent model.

4.2 The stack

Three families that can score *the same rows* are combined through a calibrated logistic stack. The split protocol matters more than the architecture:

train (354324)	the three members are fit here
meta (118108)	members score it; the stack is fit on those scores
test (118108)	members score it, the stack combines, and that is what is reported

The middle split is not decoration. Fitting the stack on member scores drawn from the members' own training rows would hand it scores far sharper than anything it will see in production, and

inflate the test number. The GNN is transductive, message passing sees every node’s features, which is the point of a graph model, but its supervised loss is masked to training rows only, so no test label reaches it.

Member	PR-AUC	Recall	Precision	Stack weight
Gradient-boosted trees	0.586	50%	64%	5.70
Graph neural network	0.412	41%	45%	2.09
Unsupervised anomaly	0.087	37%	10%	0.58
Stacked	0.589	50%	69%	

4.3 Where the decisions actually go

A PR-AUC does not answer the question an issuer asks, which is how much volume lands in a queue a human has to staff. The stacked score routes into four tiers mirroring real issuer logic. Two views of the same held-out population are reported, because each one alone misleads: fixed probability cuts are what a regulator can be shown, and leave a tier empty whenever the model is never confident enough to reach it; capacity-planned cuts are how a review queue with a fixed number of analysts is actually sized, and always fill every tier whether or not the confidence justifies it.

Decision	Action	Volume	Fraud caught	Fraud rate here
<i>Fixed probability cuts</i>				
Auto-approve	Straight through	96.63%	45.1%	1.68%
Step-up auth	Challenge the cardholder	2.10%	23.2%	39.78%
Review	Queue for a human analyst	1.27%	31.7%	89.30%
Decline	Refuse the authorization	0.00%	0.0%	0.00%
<i>Capacity-planned cuts</i>				
Auto-approve	Straight through	95.80%	41.6%	1.56%
Step-up auth	Challenge the cardholder	3.00%	28.2%	33.81%
Review	Queue for a human analyst	1.00%	24.7%	88.57%
Decline	Refuse the authorization	0.20%	5.5%	98.73%

4.4 Why a decline happened

A decline a risk analyst cannot read a reason for is not deployable under EU AI Act-era expectations, and a chargeback dispute needs a reason code, not a score. SHAP values attach per-decision contributions to the fast path’s output. The five features contributing most across the model:

Feature	Mean SHAP
V14	3.9141
V4	1.4730
V10	1.4112
V12	0.9873
V16	0.6750

SHAP values are in log-odds contribution units against the model’s base value. ULB’s V1-V28 are PCA components with no published loadings, so a component name is not a human-readable reason on this dataset, what this demonstrates is the mechanism and its cost, which carries over to a feature set with real column names.

4.5 A feature removed on purpose

The ULB dataset carries a **Time** column: seconds elapsed since the first row of one particular two-day capture. Every part of this pipeline consumed it, because each built its column list as “everything except the label”. No live authorization scorer has an equivalent value, so any lift it provides is lift the deployed model would not get, and it was also inside the fidelity distinguisher (a copula cannot reproduce a bimodal two-day activity curve, so part of that AUC was the classifier spotting a capture artifact) and inside the evasion attacker’s step size (its standard deviation is roughly 47,000 seconds, so one step moved a timestamp by over six hours and dominated the reported perturbation budget).

Measured rather than asserted: with the capture clock, PR-AUC **0.8796**; without it, **0.8768**. Identical recipe, split and seed. Everything reported in this document is the second arm.

4.6 Can it run inline?

Authorization is a synchronous decision inside a network timeout. A model that cannot answer in time is not a control, whatever it scores. Single-row scoring latency, 500 samples on kaggle notebook cpu:

p50	p95	p99	max
3.11 ms	3.67 ms	4.25 ms	7.38 ms

Single-row latency is the number that matters for an inline authorization decision; batched throughput is what a queue-based async tier would see. Neither includes network or feature-assembly time, which in a real deployment dominate model time.

5 The closed loop

5.1 Agentic arm: a frontier model attacking an agent

The red team is **gpt-5.5** reasoning about what the defense caught last round and writing a new payload each attempt, not a template library. The target is an AP2 shopping agent in a fully synthetic sandbox, explicitly instructed to treat product descriptions as untrusted data, to ignore claimed system authority in retrieved content, and never to pass a foreign account reference to the payment tool. Round 0 runs with no Mandate Firewall to establish the undefended baseline; from round 1 the firewall is inline and has been trained on every payload that got through previously.

Round	Defense	Attempts	Attacker win rate
0	None (baseline)	12	50.0%
1	Firewall inline	12	0.0%
2	Firewall inline	12	0.0%
3	Firewall inline	12	0.0%

5.2 Tabular arm: black-box evasion and hardening

XGBoost has no usable gradient, so this is a practical black-box attack rather than a gradient method: greedy coordinate descent, perturbing one feature at a time in whichever direction most reduces the predicted fraud probability, within a bounded budget, until the prediction flips below the decision threshold. Successful evasions are appended to the training set, still labelled fraud, because they *are* still fraud; only the feature values moved, and the model is refit. Each round attacks the previous round’s hardened model, so the attacker adapts to what was just fixed.

The perturbation column is in per-feature standard deviations rather than raw L2. Raw L2 is in whatever units the features happen to carry, is not comparable across feature sets, and on this data was dominated by whichever feature had the largest variance, which is how a meaningless figure of twelve thousand went unnoticed for several runs.

Round	Evasion rate	Features moved	Displacement (σ)	Clean PR-AUC
1	86.1%	3.6	1.35	0.884
2	66.1%	5.2	1.79	0.891
3	52.7%	6.3	2.04	0.891
4	46.4%	6.7	2.16	0.889
5	41.0%	7.1	2.39	0.887

The evasion rate falls from 86.1% to 41.0% across 5 rounds, while held-out clean PR-AUC moves from 0.884 to 0.887, so the hardening is not being bought by degrading the model on ordinary traffic. Note that the attacker’s displacement budget is the other half of the story: a defense that only survives because the attacker had to move a transaction implausibly far is not the same as one that closed the gap.

6 Real-world feasibility in live payments

6.1 Where each control sits in an authorization

Control	Where it runs	What has to be true
Deterministic hard rules	Inline, before scoring	Account-reference binding, line-item totals and purchase-summary amounts are checkable from the mandate itself; no model, no latency risk, no false positives on well-formed requests.
Gradient-boosted scorer	Inline, in the authorization path	Features must be assemblable inside the network timeout; see the latency profile above.
Graph and sequence models	Asynchronous, alongside	Their outputs attach to case management and step-up decisions rather than gating the authorization.
Mandate Firewall (text)	Inline at the agent boundary	Scrubs retrieved merchant content before it enters an agent’s context.
Onboarding scorer	At account opening	Not in the payment path at all; a different SLA entirely.

6.2 Fitting existing rails

Nothing here proposes a new message format. The tabular features are assembled from fields already present in an ISO 8583 authorization or its ISO 20022 equivalent: amount, merchant category, acquirer and issuer identifiers, terminal and entry mode, and the velocity counters a risk platform already maintains. The entity linkage the graph model needs (shared card, device, billing region, email domain) is exactly what an issuer already holds and what the public IEEE-CIS features stand in for here.

The agentic controls target the Agent Payments Protocol surface: an open mandate, a delegated shopping agent, and a credential provider. The four checkpoints, content scrub, checkout constraints, purchase-summary amount, account-reference binding, map onto the points where an agent’s claims meet a payment instruction, and three of the four are deterministic, which is what makes them deployable ahead of any model.

6.3 What would have to happen next

- **Labels.** Every synthetic population here is labelled by construction. Deployment means re-training on confirmed-fraud outcomes with the reporting lag that implies.
- **Drift.** The closed loop is the right shape for a fraud landscape that moves, but it needs to run continuously against production traffic, not once in a build.
- **Fair-lending review.** The onboarding scorer's thin-file false-positive rate is reported for a reason. Any deployment of it needs disparate-impact testing on protected characteristics, which this dataset cannot support.
- **Adversarial disclosure.** The evasion attacker assumes score visibility. A real deployment should assume an attacker eventually gets that too.

7 Limitations

Stated together, so none of it has to be inferred from what a section quietly omits.

- Nine of seventeen atlas entries are not simulated end to end. The coverage table says which.
- The sequence transformer's perfect score is on entirely synthetic sequences. It demonstrates the architecture, not a detection rate.
- Mule-ring and voice-scam detection are scored against fraud this project injected into real background data. The topology and behaviour are grounded; the labels are ours.
- The onboarding population is synthetic on both sides, because no public dataset labels synthetic-identity applications.
- No fidelity batch reaches an indistinguishable AUC. The generators are useful for training and stress-testing; they are not a substitute for real data.
- The agentic sandbox is a mock merchant and a mock credential provider. It reproduces the protocol shape of AP2, not a certified implementation.

8 Reproducing this

```
git clone https://github.com/kavyabhand/maxout.git && cd maxout
python3.12 -m venv .venv && source .venv/bin/activate
pip install -r requirements.txt
```

```
pytest tests/ -q                # offline; no network, no credentials
python -m janus.data.download    # ~1.3GB, public mirrors, no account
python -m janus.orchestrate.persist # regenerates every artifact
```

```
uvicorn backend.app.main:app --reload # API on :8000
cd frontend && npm install && npm run dev
```

The datasets are pulled anonymously over HTTPS from public HuggingFace mirrors, and each download is verified by exact row count and label count so a truncated file fails loudly rather than silently skewing every downstream number. There are no credentials anywhere in this repository and none are required to reproduce any figure in this document.